

CWE AI Working Group: New Entry Development

Meeting Minutes

May 9, 2025

Attendance

- Martin Hodo
- Chris Gourley
- Kevin Monette
- Dave Morse
- Caroline Rocha
- Chris Coffin
- Erick Galinkin
- Joseph George
- Raymond Pompon
- Steve Christey
- Alec Summers

Agenda

- Status Updates
- Detailed Discussion: Getting Examples of “General” CWEs That Affect AI/ML Products

Meeting Notes:

Status Updates: Steve provided a status update on CWE 4.17, mentioning its release in early April and the public availability of the content development repository (CDR). He also discussed the target for the next release in August and the need for identifying potential sub-working group leads by the end of May.

Detailed Discussion: Getting Examples of “General” CWEs That Affect AI/ML Products: Steve and Erick discussed the need to identify other general CWEs that frequently appear in AI/ML components. They proposed looking at academic research and CVEs to determine common weaknesses and update the relevant CWEs accordingly.

- **Current CWE Coverage:** Steve noted that CWE 4.17 currently has five general CWEs tagged as affecting AI/ML and three AI-specific CWEs, with a focus on injection-related issues.
- **Common Weaknesses:** Erick mentioned seeing a lot of server-side template injection and deserialization vulnerabilities in AI/ML systems, suggesting these as common weaknesses to focus on.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

- **Data-Driven Process:** Steve outlined a process to identify CVEs related to AI/ML products, determine their CWEs, and update the most common CWEs with AI/ML relevance and examples.
- **Taxonomy of AI/ML Products:** Erick and Steve discussed the taxonomy of AI/ML products, including foundational models, frameworks (TensorFlow, PyTorch), serving frameworks (VLLM, TRTLLM), and applications that integrate AI. They also considered the potential weaknesses in these products.
 - **Potential Weaknesses:** They considered potential weaknesses in these products, such as server-side template injection, deserialization vulnerabilities, and improper access control.
 - **Examples and Insights:** Erick provided examples of common vulnerabilities in AI/ML products, such as unsafe use of Jinja and deserialization issues in serving frameworks for large language models.
 - **Taxonomy Challenges:** They acknowledged the challenges in creating a formal taxonomy due to the diverse and evolving nature of AI/ML products.
- **Data Gathering and Communication:** The group decided to use email for initial data gathering and then move to the CDR for more concrete discussions. They plan to coordinate on messaging and work towards expanding CWE coverage for AI/ML products.
 - **Initial Data Gathering:** The group agreed to use email for initial data gathering to reduce friction and facilitate communication.
 - **Concrete Discussions:** They plan to move to the CDR for more concrete discussions once preliminary findings are gathered, ensuring a more structured and documented approach.

Action Items:

- **Sub Working Group Leads:** Identify and follow up with volunteers for sub working group leads to help move tasks along. (Steve, Erick Galinkin)
- **Data Gathering Process:** Coordinate and start messaging for data gathering on AI/ML product vulnerabilities through the AI working group mailing list. (Steve, Erick, Alec)

- **CWE Tagging for AI/ML:** Explore academic research to identify common weaknesses in AI/ML systems and determine specific CWE results. (Steve)
- **CWE Update Process:** Identify CVEs related to AI/ML products, determine their CWEs, and update the relevant CWEs to link them with AI/ML, using observed examples. (Steve)
- **Communication Method:** Use the AI working group mailing list for initial data gathering and then move discussions to the CDR for a more concrete record. (Steve, Erick Galinkin)